



Raport dla klienta

Badanie bezpieczeństwa sieci od środka

5

Wykryte urządzenia

10

Otwarte porty

14

Ustalenia wymagające działania

5

Luki w pokryciu badania

Sonda

Sonda demonstracyjna

Identyfikator badania

PROBKA-0000-0000-0000-DEMO

Data wykonania badania

2026-09-18 09:12:44

Przebieg badania

zakończone

Adres sondy w badanej sieci

192.0.2.250

Raport odebrany

2026-10-04 14:50:33 UTC

1. Podsumowanie badania

Ocena ryzyka wynikająca z całości badania.

Badanie objęło sieć, w której wykryto pięć urządzeń; cztery odpowiedziały na sprawdzenie portów, a na jednym (192.0.2.40) skanowanie się nie powiodło. Stan jest poważny: potwierdzono dwa krytyczne problemy na serwerze 192.0.2.30 — możliwość zdalnego wykonania polecenia przez usługę bazy danych oraz podatność w szyfrowaniu połączeń. Łącznie odnotowano 14 ustaleń wymagających działania, w tym 2 krytyczne i 5 wysokich. To oznacza, że osoba z dostępem do sieci mogła już teraz przejąć kontrolę nad serwerem i dotrzeć do danych klientów.

Nie chodzi o teoretyczne ryzyko — potwierdzono, że przez bazę danych wykonano polecenie systemowe, a samo konto administratora bazy działa bez hasła. Znajdują się w niej dane wrażliwe, m.in. numery PESEL klientów oraz numery kart płatniczych. Reakcja powinna być natychmiastowa: najpierw odcięcie i zabezpieczenie serwera 192.0.2.30, a następnie usunięcie pozostałych słabości opisanych w dalszej części raportu.

2. Ustalenia według wagi

Wszystko, co badanie wykazało, zebrane w jednym miejscu i uszeregowane od najpoważniejszego. Wagi wynikają z tego, co stwierdziły testy - ustalenie, którego test nie zdołał potwierdzić, jest oceniane niżej niż potwierdzone.

2

Krytyczne

5

Wysokie

7

Średnie

0

Informacyjne

WAGA	GDZIE	USTALENIE
Krytyczne	192.0.2.30 ssl-poodle · port 8443	SSL POODLE information leak CVE-2014-3566
Krytyczne	192.0.2.30	Potwierdzone zdalne wykonanie kodu na bazie danych (RCE) Sonda wykonała polecenie systemowe przez usługę bazy danych.
Wysokie	192.0.2.30 http-slowloris-check · port 8443	Slowloris DOS attack CVE-2007-6750
Wysokie	192.0.2.30	Konto bazy danych bez hasła root
Wysokie	192.0.2.30	Dane wrażliwe dostępne w bazie danych PESEL w crm.klienci; KARTA KREDYTOWA w crm.platnosci
Wysokie	192.0.2.20 23/TCP	Telnet dostępny w sieci Protokół przesyła hasła otwartym tekstem.
Wysokie	cała sieć	Brak blokady Gratuitous ARP — ruch w sieci można przechwycić i podsłuchać.
Średnie	192.0.2.30	Serwer WWW ujawnił ścieżki wymagające weryfikacji Wykryte podczas fuzzingu katalogów; część może być fałszywa - wymaga ręcznego potwierdzenia. https://192.0.2.30:8443/.git/config , https://192.0.2.30:8443/backup.sql , https://192.0.2.30:8443/phpinfo.php
Średnie	192.0.2.20 port 80	Panel kamery dostępny po nieszyfrowanym HTTP Wymuś HTTPS i ogranicz dostęp do sieci zarządzającej.
Średnie	192.0.2.1 port 53	Znane podatności w dnsmasq 2.80 (3 CVE, najwyższy CVSS 8.1) CVE-2021-3448, CVE-2020-25681, CVE-2020-25684 Dopasowanie po numerze wersji - wymaga potwierdzenia, czy podatny kod jest faktycznie używany.
Średnie	192.0.2.10 445/TCP	Udostępnianie plików SMB dostępny w sieci Dostęp do plików i klasyczny cel ataków w sieci lokalnej.
Średnie	192.0.2.30 3306/TCP	Baza danych MySQL dostępny w sieci Baza danych nasłuchująca w sieci.

WAGA	GDZIE	USTALENIE
Średnie	192.0.2.30 502/TCP	Modbus dostępny w sieci
Średnie	cała sieć	Porty przepuszczane na zewnątrz: 23, 445, 3389

Luki w pokryciu badania (5)

Poniższe testy nie dostarczyły wyniku. Tych obszarów badanie nie sprawdziło, więc nie można ich uznać ani za bezpieczne, ani za zagrożone.

- 192.0.2.40 — Skanowanie portów: test nie powiódł się na tym urządzeniu
- Sieci bezprzewodowe: test zablokowany przez zakres lub politykę badania
- Zatrutowanie rozgłoszeń — sonda nie przekazała wyniku
- Wycieki z katalogu LDAP — test nie wykonał się
- Bezpieczeństwo sieci bezprzewodowej — Nie udało się włączyć trybu monitora, więc nasłuch się nie odbył.

Najpoważniejsze ustalenie dotyczy serwera 192.0.2.30 — potwierdzono zdalne wykonanie polecenia przez usługę bazy danych. W praktyce oznacza to, że osoba z dostępem do sieci mogła przejąć kontrolę nad tym serwerem i robić na nim praktycznie wszystko, co potrafi jego właściciel. Równie krytyczna jest podatność w szyfrowaniu połączeń (port 8443, oznaczenie POODLE), która pozwala odczytać dane uznawane za chronione.

Wśród ustaleń o wadze wysokiej: konto administratora bazy danych bez hasła na 192.0.2.30, dane wrażliwe w tej samej bazie (PESEL w crm.klienci oraz numery kart w crm.platnosci), podatność na wyczerpanie dostępności serwera przez powolne połączenia, usługa telnet na 192.0.2.20 przysyłająca hasła jawnym tekstem oraz brak zabezpieczenia przed podmianą adresów w sieci lokalnej, co pozwala przechwycić ruch. Ustalenia o wadze średniej obejmują m.in. bramę routera 192.0.2.1 z przestarzałą wersją usługi nazw domenowych, udział plików na 192.0.2.10, bazę MySQL oraz protokół przemysłowy Modbus na 192.0.2.30, a także przepuszczanie na zewnątrz portów 23, 445 i 3389.

Warto pamiętać o ograniczeniach badania: urządzenie 192.0.2.40 nie zostało przeskanowane, testy sieci bezprzewodowej i katalogu LDAP się nie odbyły, a wynik testu zatrutowania rozgłoszeń nie został przekazany. Tych obszarów nie sprawdzono, więc nie wiadomo, co się w nich znajduje.

3. Wykryte urządzenia

Przegląd segmentu sieci i lista wszystkich urządzeń, które się w nim odezwały. Urządzenie, które odpowiedziało przy wykrywaniu, ale zamilkło przy skanowaniu portów, jest odnotowane osobno.

Test nie powiódł się na 1 urządzeniu: 192.0.2.40. Wyniki poniżej dotyczą wyłącznie urządzeń, które udało się sprawdzić.

ADRES	ADRES SPRZĘTOWY	PRODUCENT I MODEL	STAN
192.0.2.1	02:00:5e:00:53:01	Acme Networks GW-200 Linux 4.x (router)	3 otwarte porty
192.0.2.10	02:00:5e:00:53:0a	NorthStore NAS-4B Linux (NAS)	2 otwarte porty
192.0.2.20	02:00:5e:00:53:14	Visinet IP-Cam 3 Embedded Linux	2 otwarte porty
192.0.2.30	02:00:5e:00:53:1e	Generic Server Co. CentOS 7	3 otwarte porty
192.0.2.40	—	nieznany	skanowanie nieudane test przekroczył limit czasu

Wykrytych urządzeń: 5, odpowiedziało na skanowanie portów: 4.

W sieci wykryto pięć urządzeń; cztery odpowiedziały na sprawdzenie portów, jedno (192.0.2.40) nie odpowiedziało, bo skanowanie przekroczyło limit czasu. Zidentyfikowano router 192.0.2.1, serwer plików 192.0.2.10, kamerę sieciową 192.0.2.20 oraz serwer 192.0.2.30, na którym skupia się najwięcej problemów. To typowy zestaw dla małej lub średniej firmy, ale właśnie na serwerze 192.0.2.30 nagromadziły się ustalenia krytyczne.

4. Usługi dostępne w sieci

Sprawdzenie, co nasłuchuje na każdym wykrytym urządzeniu i w jakiej wersji. Wynik zostaje zachowany w pełnej postaci, nie w formie skrótu.

Test nie powiódł się na 1 urządzeniu: 192.0.2.40. Wyniki poniżej dotyczą wyłącznie urządzeń, które udało się sprawdzić.

URZĄDZENIE	PORT	USŁUGA	WERSJA ROZPOZNANA PRZEZ SONDĘ
192.0.2.1	53/TCP	domain	dnsmasq 2.80
192.0.2.1	80/TCP	http	lighttpd 1.4.59
192.0.2.1	443/TCP	https	lighttpd 1.4.59
192.0.2.10	445/TCP	microsoft-ds	Samba smbd 4.15.13
192.0.2.10	5000/TCP	http	Synology DSM httpd
192.0.2.20	23/TCP	telnet	nie ustalono
192.0.2.20	554/TCP	rtsp	nie ustalono
192.0.2.30	22/TCP	ssh	OpenSSH 7.4
192.0.2.30	3306/TCP	mysql	MySQL 5.7.38
192.0.2.30	8443/TCP	https	nie ustalono

Otwartych portów łącznie: 10, na 4 urządzeniach.

Na urządzeniach wystawiono łącznie dziesięć otwartych usług. Na 192.0.2.30 działają: zdalny dostęp do konsoli, baza MySQL oraz serwer WWW na porcie 8443 — i to właśnie te usługi są źródłem najpoważniejszych problemów. Na 192.0.2.20 działa telnet, który przesyła hasła jawnym tekstem, przez co łatwo je podsłuchać. Na 192.0.2.10 udostępniane są pliki przez usługę SMB, na 192.0.2.1 działa serwer nazw domenowych w przestarzałej wersji, a na 192.0.2.30 dodatkowo protokół przemysłowy Modbus.

5. Pogłębione testy podatności

Testy uruchamiane przeciwko znalezionym usługom. Ustalenie oznaczone jako wymagające uwagi to takie, które nie zakończyło się zwykłym „nic nie znaleziono”.

URZĄDZENIE	TEST	USTALENIE
192.0.2.30	ssl-poodle	VULNERABLE: SSL POODLE information leak State: VULNERABLE IDs: CVE:CVE-2014-3566
192.0.2.30	http-slowloris-check	VULNERABLE: Slowloris DOS attack State: LIKELY VULNERABLE IDs: CVE:CVE-2007-6750

Ustaień łącznie: **3**, w tym wymagających uwagi: **2**, pozostałe 1 zakończyło się wynikiem czystym.

Uruchomiono pogłębione testy przeciwko znalezionym usługom. Dwa z nich zakończyły się wynikiem potwierdzającym problem: podatność POODLE w szyfrowaniu na 192.0.2.30 oraz podatność na wyczerpanie dostępności serwera WWW tym samym adresem (Slowloris). Jedno z pozostałych badań zakończyło się wynikiem czystym — stan prawidłowy.

Osobno odnotowano, że na 192.0.2.1 działa przestarzała wersja usługi nazw domenowych z trzema znanymi podatnościami (najwyższa ocena 8,1). To dopasowanie po numerze wersji, więc trzeba potwierdzić ręcznie, czy podatny fragment kodu jest faktycznie używany. Podobnie część wykrytych ścieżek na serwerze WWW 192.0.2.30 może być fałszywym trafieniem i wymaga sprawdzenia.

6. Ekspozycja i poświadczenia

Udziały plików dostępne bez uwierzytelnienia, ruch przestarzałych mechanizmów rozwiązywania nazw, pozostawione domyślne dane logowania oraz informacje wyciekające z katalogu firmowego do klientów anonimowych.

BADANY OBSZAR	WYNIK
Anonimowe sesje i udziały SMB	stan prawidłowy — nie stwierdzono podatności
Zatrutowanie rozgłoszeń	brak danych Sonda nie przekazała wyniku tego testu.
Skanowanie szablonami znanych podatności	stan prawidłowy — nie stwierdzono podatności
Domyślne poświadczenia	stan prawidłowy — nie stwierdzono podatności
Wycieki z katalogu LDAP	test nie wykonał się Test nie został uruchomiony, więc ten obszar pozostaje niesprawdzony.
Ryzyka infrastrukturalne	stan prawidłowy — nie stwierdzono podatności

Jeden moduł badania nie wykonał się poprawnie. Wyniku tych testów nie należy czytać jako „nic nie znaleziono” - one się nie odbyły.

Sprawdzono anonimowe sesje i udziały plików SMB — nie stwierdzono podatności. Domyślne poświadczenia również nie dały trafień, podobnie jak skanowanie szablonami znanych podatności i ryzyka infrastrukturalne. Test wycieków z katalogu LDAP nie wykonał się, więc nic o nim nie wiadomo. Test zatrutowania rozgłoszeń nie przyniósł wyniku — sonda go nie przekazała; oznacza to, że ten obszar pozostał niesprawdzony.

7. Protokoły przemysłowe ICS i OT

Punkty końcowe sterowania przemysłowego, takie jak CODESYS Runtime, EtherNet/IP czy IEC 60870-5-104, które zwykle nie mają czego szukać w sieci biurowej.

URZĄDZENIE	PORT	PROTOKÓŁ	STAN	OCENA SONDY
192.0.2.30	502/TCP	Modbus	open	WARNING

Punktów końcowych ICS/OT: 1. Stan open|filtered oznacza, że sonda nie mogła rozstrzygnąć, czy port jest otwarty, czy odfiltrowany.

W sieci znaleziono jeden punkt końcowy protokołu przemysłowego: Modbus na 192.0.2.30, port 502, z oceną ostrzegawczą. Protokoły tego typu służą do sterowania urządzeniami przemysłowymi i zwykle nie powinny być wystawione w zwykłej sieci biurowej. Ich obecność na serwerze ogólnym zwiększa ryzyko, bo nie zabezpieczają one dostępu i łatwo je zakłócić.

8. Diagnostyka sieci

Kondycja i konfiguracja sieci: opóźnienia, DNS, podatności na podsłuch i podszywanie się, zabezpieczenie portu dostępowego, ruch wychodzący oraz przepustowość. Poniżej znajdują się wyłącznie te testy, których wynik sonda przekazała.

Opóźnienia w sieci

Status	ok
Najniższe	0.4 ms
Średnie	0.8 ms
Najwyższe	1.9 ms

Kondycja DNS

Status	ok
Odpytany serwer	192.0.2.1
Czas odpowiedzi	12 ms

Podatność na podsłuch (MITM)

Status	ok
▲ Brak blokady Gratuitous ARP — ruch w sieci można przechwycić i podsłuchać.	
Assessment	Przełącznik nie blokuje Gratuitous ARP - ruch w segmencie można przekierować.

Filtrowanie ruchu wychodzącego

Status	ok
Porty przepuszczane na zewnątrz	▲ 23, 445, 3389

Bezpieczeństwo sieci bezprzewodowej

Status	blocked
Reason	foreign_block
▲ Nie udało się włączyć trybu monitora, więc nasłuch się nie odbył.	
Przechwycone ramki EAPOL	0

Przepustowość łącza

Opóźnienie (ping)	18.4 ms
Pobieranie	184.2 Mbit/s
Wysyłanie	41.7 Mbit/s

Najbardziej obciążające urządzenia

ADRES	PAKIETY	RUCH ŁĄCZNIE	WYSŁANE	ODEBRANE
192.0.2.10	182340	136,3 MB	90000 pk · 76,3 MB	92340 pk · 60,0 MB
192.0.2.1	90120	17,5 MB	45000 pk · 8,6 MB	45120 pk · 9,0 MB

Opóźnienia w sieci są prawidłowe (od 0,4 do 1,9 ms), a serwer nazw domenowych odpowiada szybko. Poważny problem dotyczy ochrony przed podsłuchem: przełącznik nie blokuje rozgłoszeń, przez co ruch w sieci można przekierować i podsłuchać — stan zgłoszono jako niepokojący. Dodatkowo na zewnątrz przepuszczane są porty 23, 445 i 3389, czyli kanały, które nie powinny być otwarte na świat. Test bezpieczeństwa sieci bezprzewodowej się nie odbył (nie udało się włączyć trybu nasłuchu), więc nie wiadomo, jaki jest jej stan.

9. Plan naprawy

Działania wynikające wyłącznie z ustaleń tego badania, uszeregowane od najpilniejszego.

1. Natychmiast odizolować serwer 192.0.2.30 od sieci i zabezpieczyć dowody przed dalszą pracą — to urządzenie z potwierdzonym przejęciem kontroli i danymi wrażliwymi.
2. Ustawić hasło dla konta administratora bazy danych (obecnie brak hasła) i odebrać mu dostęp zdalny spoza samego serwera.
3. Usunąć dane kart płatniczych i numerów PESEL z bazy `crm.platnosci` i `crm.klienci` albo objąć je szyfrowaniem i ograniczyć dostęp do minimum.
4. Wyłączyć dostęp do bazy MySQL (port 3306) oraz do Modbus (port 502) z sieci — powinny być widoczne tylko dla zaufanych urządzeń.
5. Wyłączyć telnet na 192.0.2.20 i zastąpić go szyfrowanym sposobem dostępu; panel kamery przenieść na HTTPS i ograniczyć do sieci zarządzającej.
6. Zaktualizować lub wyłączyć podatne szyfrowanie na porcie 8443 serwera 192.0.2.30 oraz przygotować usługę WWW na wzrost liczby połączeń, aby nie dała się zatrzymać prostym przeciążeniem.
7. Usunąć z filtrowania ruchu wychodzącego porty 23, 445 i 3389.
8. Wyłączyć lub zaktualizować przestarzałą usługę nazw domenowych na 192.0.2.1 po potwierdzeniu, że podatny kod jest używany.
9. Ograniczyć dostęp do udostępniania plików na 192.0.2.10 do niezbędnych urządzeń.
10. Rozwiązać problem przechwytywania ruchu w sieci lokalnej (ochrona przed podmianą adresów), aby nikt niepowołany nie mógł podsłuchiwać transmisji.

Ponowne przeprowadzenie audytu weryfikującego przy pomocy sprzętowego analizatora w celu technicznego potwierdzenia skuteczności wdrożonych zabezpieczeń.